SECURITY · RELEASE RUNBOOK

Release runbook: security wave 1

What to do on the production servers when the security work (Task 041 wave 1 and the pentest fixes) is merged to main and deployed.

Classification: **CONFIDENTIAL / TLP:AMBER** · Written: **2026-10-15** · Applies to: **main after security/wave-1 and dev are merged**

1. In short

This release carries the fixes from Haboob's pentest (M-001 to M-005) and Task 041 wave 1. It needs **no database migration** and **no new Composer package**. The frontend and the admin move to **Next.js 15.5.27**, so both need `yarn install` and Node 20.9 or later.

> **Order matters: frontend, then backend, then admin.** The frontend must send the reCAPTCHA token before the backend requires it, and the backend must stop requiring `back_link` before the admin stops sending it.

Not in this release: B16 (`TRUSTED_PROXIES` , the real visitor IP) stays on its own branch, `security/b16-trusted-proxies` , until it is tested and devops has confirmed the origin is reachable only through Cloudflare.

2. Before deploying

Backend .env

Add or change:

```
ADMIN_PANEL_URL=https://admin-register.tourise.com
GOOGLE_RECAPTCHA_ENFORCE_SCORE=false
GOOGLE_RECAPTCHA_HOSTNAMES=register.tourise.com,admin-register.tourise.com
LOG_LEVEL=info
LOG_CHANNEL=daily
```

Setting	Why	Needed
`ADMIN_PANEL_URL`	Admin reset and invite links are built from it (B3). Unset, they point at localhost	**Required**
`GOOGLE_RECAPTCHA_ENFORCE_SCORE=false`	Observation mode for the first days: scores are logged, nobody is refused for a low score (B7)	Recommended start
`GOOGLE_RECAPTCHA_HOSTNAMES`	A token made on another site with our key is refused (B7)	Recommended

Setting	Why	Needed
`LOG_LEVEL=info`	Only if it is `warning` or `error` today: otherwise the score lines are not written	Check
`LOG_CHANNEL=daily`	One log file a day, kept 14 days, so `laravel.log` does not grow forever	Optional

Check, no change expected:

Setting	Must be
`APP_DEBUG`	`false`
`GOOGLE_RECAPTCHA_SECRET`	set (without it every registration and admin login is refused)
`CORS_ALLOWED_ORIGINS`	the admin and the public site only
`SESSION_SECURE_COOKIE`	absent, or `true`; never a blank `SESSION_SECURE_COOKIE=` line
`MOBILE_DEMO_EMAIL`, `MOBILE_DEMO_OTP`	not set
`TRUSTED_PROXIES`	not set (B16 is not in this release)

Checks on the servers

1. `node -v` on the frontend and admin servers: **20.9 or later**.
2. `git status` in the frontend and admin: `yarn.lock` unmodified (if not, `git checkout -- yarn.lock`).
3. The backend **queue worker** is running: forgot-password emails now go through it (B10).
4. Admin links that will stop working (they now last 48 hours, B3); tell these admins to ask for a new one: `SELECT email FROM admin_invites WHERE created_at IS NULL OR created_at < NOW() - INTERVAL 48 HOUR`
5. `curl -sI https://api-register.tourise.com/api/health`: the server in front must **not** send its own `Content-Security-Policy` or `Permissions-Policy` (the app now sends them, B20).
6. Ask devops whether an uptime monitor reads `app` or `env` from `/api/health` (both are removed, B17).
7. Optional: share texts with HTML, which will now show as literal tags (B4): `SELECT slug FROM categories WHERE share_text_en REGEXP '[<>]' OR share_text_ar REGEXP '[<>]'`

3. Deploy

Frontend first

```
git pull
yarn install --frozen-lockfile
yarn production
pm2 restart tourise-frontend tourise-frontend-cluster
```

Restart both process sets, or one keeps serving the old build.

Then the backend

```
git pull
composer install --no-dev --optimize-autoloader
php artisan migrate --force
php artisan config:cache
php artisan route:cache
php artisan event:clear
php artisan queue:restart
```

`migrate` has nothing to run in this release; it is there out of habit and is harmless.

Then the admin

```
git pull
yarn install --frozen-lockfile
yarn production
pm2 restart <admin process>
```

4. Right after deploying

1. From the backend folder: `scripts/post-deploy-security-check.sh`. **Every line must say OK.**
2. `php artisan config:show app.debug` prints `false`.
3. Admin, click through: a save, an upload, an export, a delete and a toggle button. A 403 means the server in front of the admin does not pass the real `Host` header (B6, devops).
4. Forgot-password: the email arrives, and its link starts with `https://admin-register.tourise.com/`.
5. Downloads: the guests, invitations and dashboard exports open; a PDF, a badge and a calendar file open (B8, B20).
6. Public site: one registration form through to the photo step; the email field check works (M-005).
7. Tell the team: conference logos and icons are now PNG, JPG or WebP only, no SVG (B13).

5. A few days later

1. Read the reCAPTCHA scores: `grep -o '"score":[0-9.]*' storage/logs/laravel.log | sort | uniq -c`
2. Refusals and errors, if any: `grep 'recaptcha.verify' storage/logs/laravel.log | grep -v '"verdict":"pass"'` and `grep -E 'recaptcha\.(unreachable|upstream_error|malformed_response|misconfigured)' storage/logs/laravel.log`
3. If real users score well above 0.3: `GOOGLE_RECAPTCHA_ENFORCE_SCORE=true`, then `php artisan config:cache`.
4. Put the release date into the response to STA (`security/pentest-2026-09/PENTEST_RESPONSE`), send it, and ask Haboob to retest.

6. Where the detail is

What	Where
Each item, its commits and its own deploy note	`tasks/041-security-port-wave-1/TASK.md` (Log, Deploy checklist)
The pentest findings and their status	`security/README.md` (tracker)
The response to STA and Haboob	`security/pentest-2026-09/PENTEST_RESPONSE`